SE LAB 5: Static Code Analysis

Sheetal Bevinakatti
SRN: PES2UG24CS466

Before: Baseline Analysis

I ran the original program and checked it with Pylint, Bandit and Flake8 before making changes.

```
(base) PS C:\Users\sheetal\L5_29_digital_wallet> python digital_wallet.py
OTP sent: 424070
Payment to Book Store declined
Wrong PIN for payment to Grocery Mart
credit 500 Card
debit 180 Coffee Corner
debit 420 Pharmacy
Cashback on 420: 8.4
Gateway check: False
Final balance: Rs. 1900.0
Total credited: 2500
```

Original program output

pylint_before.txt

```
************* Module digital_wallet
digital_wallet.py:1:0: C0114: Missing module docstring (missing-module-docstring)
digital_wallet.py:9:0: C0103: Constant name "daily_limit" doesn't conform to UPPER_CASE naming style (invalid-name)
digital_wallet.py:13:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:13:0: C0103: Function name "hashPin" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:17:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:17:0: C0103: Function name "addMoney" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:17:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
digital_wallet.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:27:0: C0103: Function name "setDailyLimit" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:27:18: C0103: Argument name "newLimit" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:28:4: W0603: Using the global statement (global-statement)
digital_wallet.py:32:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:32:0: C0103: Function name "payMerchant" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:45:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:45:0: C0103: Function name "miniStatement" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:50:0: C0103: Function name "cashbackFor" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:50:24: C0103: Argument name "merchantType" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:50:24: W0613: Unused argument 'merchantType' (unused-argument)
digital_wallet.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:54:0: C0103: Function name "checkGateway" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:58:0: C0103: Function name "receiptPath" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:63:0: C0116: Missing function or method docstring (missing-function-docstring)
digital_wallet.py:78:4: C0103: Variable name "creditAmounts" doesn't conform to snake_case naming style (invalid-name)

-----------------------------------
Your code has been rated at 5.69/10
```

Pylint before fixes — score 5.69/10



Bandit before fixes

Before and After Results

flake8_before.txt

```
1  digital_wallet.py:76:51: E261 at least two spaces before inline comment
2  digital_wallet.py:78:18: E225 missing whitespace around operator
3  digital_wallet.py:79:28: E231 missing whitespace after ','
4  digital_wallet.py:80:1: E305 expected 2 blank lines after class or function definition, found 0
5
```

Flake8 before fixes

After fixing the reported issues

Pylint: 10.00/10. **Bandit:** No issues found. **Flake8:** No output, so no style issues were reported.

```
(base) PS C:\Users\sheetal\L5_29_digital_wallet> python -m pylint digital_wallet.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 7.79/10, +2.21)
```

Pylint after fixes — score 10.00/10

```
(base) PS C:\Users\sheetal\L5_29_digital_wallet> python -m pylint digital_wallet.py > pylint_after_security.txt
(base) PS C:\Users\sheetal\L5_29_digital_wallet> Get-Content pylint_after_security.txt
************* Module digital_wallet
digital_wallet.py:116:0: C0305: Trailing newlines (trailing-newlines)
digital_wallet.py:14:0: C0103: Constant name "daily_limit" doesn't conform to UPPER_CASE naming style (invalid-name)
digital_wallet.py:18:0: C0103: Function name "hashPin" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:25:0: C0103: Function name "addMoney" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:42:0: C0103: Function name "setDailyLimit" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:42:18: C0103: Argument name "newLimit" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:44:4: W0603: Using the global statement (global-statement)
digital_wallet.py:48:0: C0103: Function name "payMerchant" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:66:0: C0103: Function name "miniStatement" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:74:0: C0103: Function name "cashbackFor" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:74:24: C0103: Argument name "merchantType" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:74:24: W0613: Unused argument 'merchantType' (unused-argument)
digital_wallet.py:79:0: C0103: Function name "checkGateway" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:86:0: C0103: Function name "receiptPath" doesn't conform to snake_case naming style (invalid-name)
digital_wallet.py:108:4: C0103: Variable name "creditAmounts" doesn't conform to snake_case naming style (invalid-name)

--------------------------------------------------------------------
Your code has been rated at 7.79/10 (previous run: 5.69/10, +2.10)
```

Pylint report after the security changes

Known Issue Table

These are the main issues I noted from the original reports and the changes I made. Line numbers are from the original version, so they may be different in the final code.

Issue	Type	Line(s)	What was wrong	What I changed
Gateway secret in code	Security	6	The secret was written directly in the Python file.	Read it from the GATEWAY_SECRET environment variable.
SHA-1 used for PIN	Security	13–15	SHA-1 is weak for storing a PIN hash.	Changed to PBKDF2-HMAC-SHA256 and used compare_digest to check it.
Unsafe temp filename	Security	60–61	mktemp() only gives a filename and does not create the file safely.	Used NamedTemporaryFile instead.
OTP used random	Security	64	random.randint() is not meant for security-related tokens.	Used secrets.randbelow() to make the six-digit OTP.
List as default argument	Bug	17	The same default list could be reused between calls.	Used None as the default and created the list inside the function.
Function names	Code quality	Multiple	Names like addMoney did not follow Python's usual naming style.	Changed function names to snake_case.
Global daily limit	Code quality	27–29	The setter changed a global variable.	Made the setter return the limit and passed it to the payment function.
Unused cashback argument	Code quality	50	merchantType was passed in but not used.	Kept it optional for the demo call and marked it as unused.
Formatting problems	Style	76–80	Flake8 reported spacing and blank-line issues.	Fixed the formatting; the final Flake8 report was empty.
Missing docstrings	Code quality	Multiple	Some functions did not explain what they do.	Added short docstrings to the functions.

Final Check and Reflection

Final program output

```
(base) PS C:\Users\sheetal\L5_29_digital_wallet> python digital_wallet.py
OTP sent: 424070
Payment to Book Store declined
Wrong PIN for payment to Grocery Mart
credit 500 Card
debit 180 Coffee Corner
debit 420 Pharmacy
Cashback on 420: 8.4
Gateway check: False
Final balance: Rs. 1900.0
Total credited: 2500
```

Program output example

Final results

Check	Result
Bandit	No issues found
Pylint	10.00/10
Flake8	No output / no style issues reported
Program	Final balance: Rs. 1900.0; total credited: 2500

Reflection

1. What did I learn from static code analysis?

I learned that static analysis can point out coding mistakes, style problems and possible security issues before submitting the program. Each tool checks a different part of the code.

2. How were the tools different?

Pylint showed naming and code-quality issues, Flake8 showed formatting problems, and Bandit pointed out possible security risks. Using all three gave me a better idea of what needed fixing.

3. What changes did I make?

I moved the gateway secret out of the code, changed the PIN hashing method, used secrets for OTP generation, and fixed the temporary-file function. I also fixed naming and formatting issues and ran the program again.

4. What are the limitations of these tools?

A clean report does not guarantee that a program is fully secure or correct. I still need to test how it runs. The wallet is only a lab demo and should not be used for real payments.